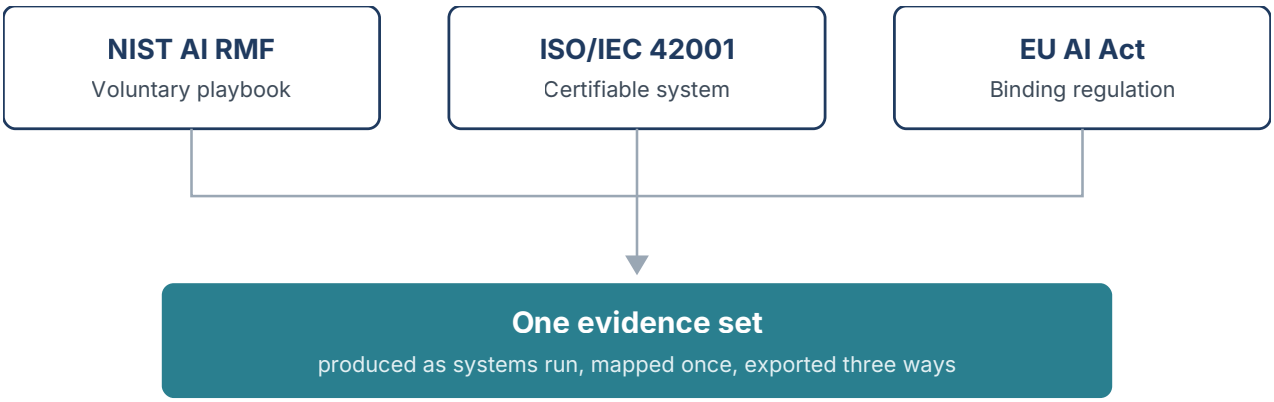
TECHNICAL WHITE PAPER · AI GOVERNANCE

Three Frameworks, One Evidence Set

Operationalizing NIST AI RMF, ISO/IEC 42001 and the EU AI Act as a single governance evidence base, with Credo AI as a worked example



System of record above, control plane beneath, evidence flowing between them

Aejaz Sheriff Quaraishi
Enterprise and AI Architect · linkedin.com/in/asheriff

Version	2.0, November 2026
Sources current to	November 4, 2026
Audience	Chief AI, data, risk and compliance officers; enterprise and solution architects
Status	Independent position paper. Not legal advice. Disclosure on page 21.

ABSTRACT

Enterprise AI governance programs increasingly answer to three frameworks at once: the NIST AI Risk Management Framework, the ISO/IEC 42001 management system standard and the EU AI Act. Run as separate programs, they produce duplicate risk registers and evidence that drifts apart between audits. This paper sets out a single-evidence-set approach in which governance artifacts are produced once, as systems operate, and mapped to each framework's provisions. It provides an activity-level crosswalk to NIST functions, ISO/IEC 42001 clauses and Annex A control objectives, and EU AI Act articles; a reference architecture that separates the governance system of record from the runtime control plane; a minimum evidence record; a seven-step implementation sequence with exit criteria; a requirement-to-capability map using Credo AI as the worked example; and a check of commonly repeated framework claims against sources current to November 2026.

KEY FINDINGS

- **The frameworks do different jobs.** NIST AI RMF guides how to manage AI risk. ISO/IEC 42001 lets an accredited auditor confirm the organization does it consistently. The EU AI Act imposes legal obligations, with fines for prohibited practices of up to €35 million or 7 percent of worldwide annual turnover.
- **The overlap is large but incomplete.** Practitioner estimates put ISO/IEC 42001's coverage of the organizational foundation for EU high-risk obligations at roughly 60 to 80 percent. The gaps are procedural (conformity assessment, CE marking, registration) and system-specific (Annex IV technical documentation, data governance, measured accuracy).
- **The EU timeline moved.** The 2026 Digital Omnibus deferred high-risk obligations to December 2, 2027 for standalone systems and August 2, 2028 for AI embedded in regulated products. Prohibited practices, general-purpose AI duties and transparency obligations were not deferred.
- **A governance platform needs a control plane beside it.** Platforms such as Credo AI are strong as a system of record. Enforcement on live AI traffic generally sits in a model gateway and policy engine, and Credo AI's own product page lists its gateway and CI/CD enforcement integrations as planned.
- **Several widely repeated claims are out of date.** NIST AI RMF is no longer named in current federal AI memoranda, and provider ISO/IEC 42001 certificates don't extend to customers.

CONTENTS

1 Introduction . . . 3
2 Three frameworks, three jobs . . . 4
3 Designing one evidence set . . . 7
4 Reference architecture: system of record and control plane . . . 9
5 Worked example: Credo AI . . . 11
6 Implementation sequence . . . 12
7 Requirement-to-capability map . . . 16
8 Sector considerations . . . 17
9 Common claims, checked . . . 18
10 Evaluating a governance platform . . . 19
11 Conclusion . . . 20
About the author and disclosure . . . 21
References . . . 22

1 Introduction

Most enterprise AI governance programs now answer to three frameworks at the same time, and most of them answer to each one separately.

The NIST AI Risk Management Framework (AI RMF) is a voluntary playbook for managing AI risk. ISO/IEC 42001 is a certifiable standard for an AI management system. The EU AI Act is binding law for organizations whose AI systems are placed on the EU market or whose output is used there. A program that treats these as three workstreams ends up with three risk registers, three policy sets and three bodies of evidence. By the second audit cycle those bodies of evidence disagree with each other, and nobody can say which one reflects the systems actually in production.

This paper describes the alternative: a single evidence set. Governance artifacts are produced once, at the point where the work happens, tagged with the framework provisions they satisfy, and exported in each framework's terms. The approach depends on two things that the paper treats in detail. The first is a crosswalk precise enough to tag evidence against (Section 3). The second is an architecture in which evidence comes from systems that ran, not from forms that people fill in (Section 4).

1.1 Scope and method

The paper covers the three frameworks as they stood on November 4, 2026, including the EU Digital Omnibus on AI adopted in mid-2026 and Colorado's SB 26-189. It uses Credo AI as a worked example because the vendor publishes policy packs for all three frameworks and documents its capabilities publicly. Descriptions of Credo AI come from the vendor's product page [21] and were not independently tested. The method is framework-first, and nearly all of it applies to comparable platforms.

Regulatory summaries are provided for architecture and planning purposes. They are not legal advice, and organizations should confirm their obligations with counsel. Where a figure is an estimate rather than an official number, the text says so.

1.2 Audience

The primary readers are chief AI, data, risk and compliance officers deciding how to structure a governance program, and the enterprise and solution architects who will build the platforms beneath it. Sections 2 and 3 are framework analysis. Sections 4 through 7 are design and implementation. Sections 8 through 10 cover sector rules, claim verification and platform evaluation.

2 Three frameworks, three jobs

The three frameworks differ most in how binding they are and in how conformance is verified. Getting that distinction right is the first step to running them together, because it determines which framework sets the shape of each artifact and which ones only consume it.

Table 1. The three frameworks compared

	NIST AI RMF	ISO/IEC 42001	EU AI Act
What it is	Voluntary risk management framework	Certifiable AI management system standard	Binding EU regulation (Regulation (EU) 2024/1689)
Published	January 2023 (AI RMF 1.0); Generative AI Profile, July 2024	December 2023; adopted as EN ISO 42001:2026 in March 2026	In force August 1, 2024; obligations phased to August 2028
Structure	Four functions (Govern, Map, Measure, Manage), 19 categories, 72 subcategories	Management system clauses 4 to 10; Annex A control objectives A.2 to A.10	Risk tiers: prohibited, high-risk, transparency obligations, minimal; separate duties for general-purpose AI models
Applies to	Any organization that adopts it	Any organization that seeks certification	Providers and deployers whose AI is placed on the EU market or whose output is used in the EU
Verified by	No certification; internal review or customer due diligence	Two-stage audit by an accredited certification body; annual surveillance; three-year cycle	Conformity assessment for high-risk systems; market surveillance authorities; administrative fines

Sources: [1] [3] [12] [13] [15].

2.1 NIST AI RMF

NIST published AI RMF 1.0 (NIST AI 100-1) in January 2023 [1]. It organizes AI risk work into four functions broken into 19 categories and 72 subcategories [3]. The functions aren't a sequence. Govern is cross-cutting: it sets the policies, accountability and culture within which the other three operate. Map, Measure and Manage are then applied iteratively across a system's life, as Figure 1 shows. NIST's Generative AI Profile (NIST AI 600-1, July 2024) extends the framework to risks specific to generative systems [2] [3].

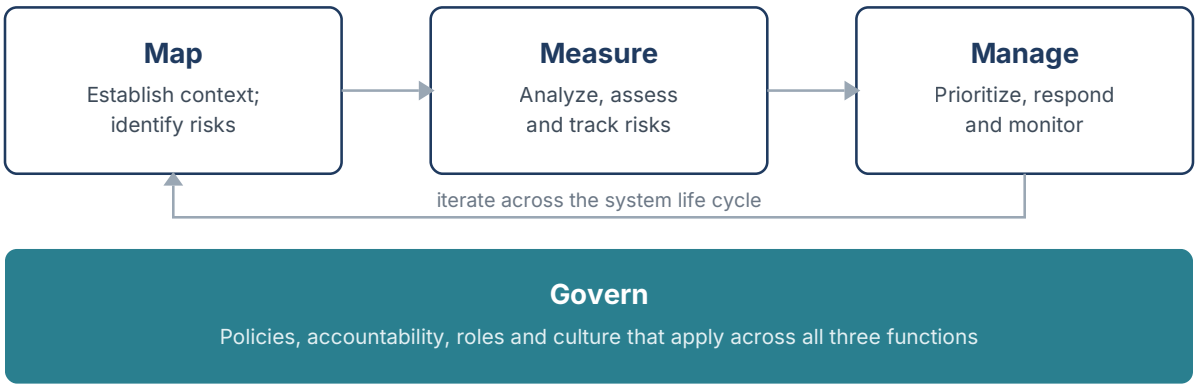


Figure 1. NIST AI RMF functions. Govern is cross-cutting rather than a first step; Map, Measure and Manage are applied iteratively. Adapted from NIST AI 100-1 [1].

The framework is voluntary and offers no certification. Its standing in US federal policy has also changed. The 2024 Office of Management and Budget (OMB) memoranda on federal AI use and acquisition drew on it. Their April 2025 replacements, M-25-21 and M-25-22, don't reference the AI RMF or ISO/IEC 42001 by name [4], though commentators note that M-25-21's minimum practices for high-impact AI cover similar ground. The July 2025 AI Action Plan directed NIST to revise the framework [3]. In practice, vendors selling to federal agencies should answer against M-25-21's minimum practices, while AI RMF alignment remains a common reference point in commercial procurement.

2.2 ISO/IEC 42001

ISO/IEC 42001:2023 specifies requirements for establishing, implementing, maintaining and continually improving an AI management system (AIMS) [5]. It uses the same harmonized structure as ISO/IEC 27001 and ISO 9001, so it fits beside the security and quality management systems many enterprises already run. Clauses 4 to 10 hold the management system requirements. Annex A lists reference control objectives and controls, which the organization selects through risk treatment and justifies in a statement of applicability (Figure 2).

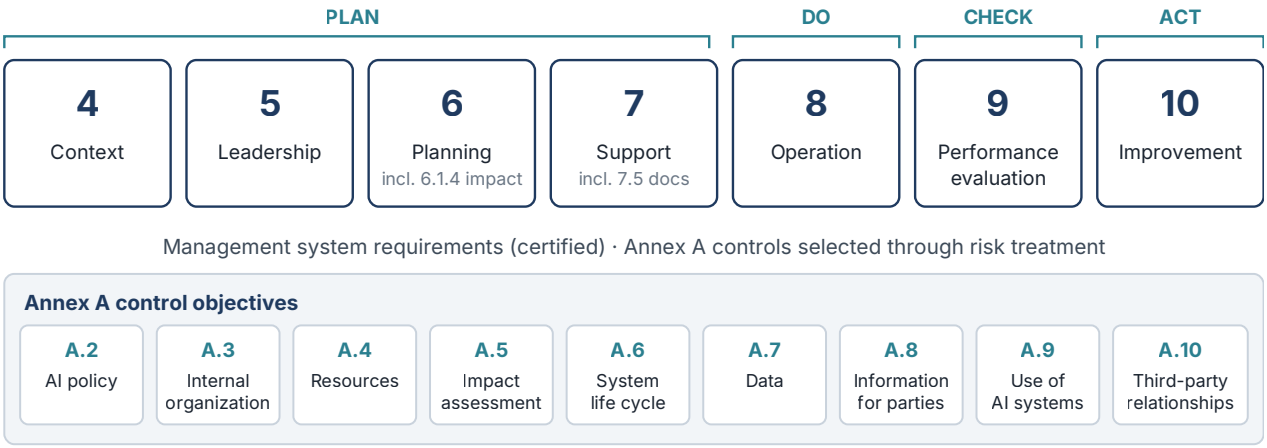


Figure 2. ISO/IEC 42001 structure. Clauses 4 to 10 follow the harmonized management system structure, commonly read as a plan-do-check-act cycle. Annex A control objectives are selected through risk treatment and justified in the statement of applicability. Control objective titles are abbreviated.

What distinguishes ISO/IEC 42001 is independent certification. Certification follows a two-stage audit by an accredited body, and certificates run for three years with annual surveillance audits [15]. That has made the standard a procurement signal. AWS announced the first ISO/IEC 42001 accredited certification by a major cloud provider in November 2024, covering Amazon Bedrock, Amazon Q Business, Amazon Textract and Amazon Transcribe [7], and completed its first surveillance audit with no findings in November 2025 [8]. Microsoft 365 Copilot and Copilot Chat were certified in March 2025 [10] and recertified in 2026 [6]. In Europe, the standard was adopted as EN ISO 42001:2026 in March 2026 without technical change [12].

CERTIFICATION HAS A SCOPE

A certificate covers the certified organization's management of the services within its scope. AWS states that customers are not certified by association [9]. Microsoft states that customers may use its certification in their own compliance assessment but remain responsible for having their own controls assessed [11]. Building on certified services makes a customer's own certification easier. It doesn't replace it.

2.3 EU AI Act

Regulation (EU) 2024/1689 entered into force on August 1, 2024 [13]. It is the one framework of the three that an organization in scope can't opt out of. It applies to providers and deployers established outside the EU where the output of their AI system is used in the Union, and fines for violating its prohibited-practice rules reach €35 million or 7 percent of worldwide annual turnover, whichever is higher [15]. Lower ceilings apply to other infringements.

The timeline moved in 2026. The Digital Omnibus on AI, adopted by the European Parliament on June 16 and the Council on June 29 and published in the Official Journal on July 24, deferred the high-risk obligations [14]. It left the prohibited-practice rules, general-purpose AI model duties and transparency obligations in place. Figure 3 shows the dates now in force.

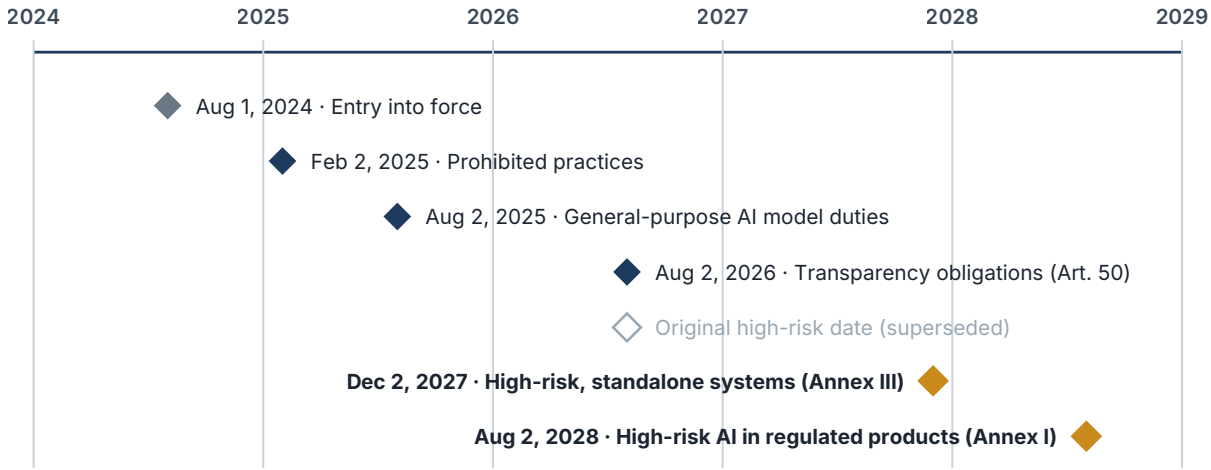


Figure 3. EU AI Act application dates after the 2026 Digital Omnibus, drawn to scale. The two highlighted dates are the deferred high-risk obligations [14].

For high-risk systems, providers must meet requirements on risk management (Article 9), data and data governance (Article 10), technical documentation (Article 11 and Annex IV), record keeping (Article 12), transparency to deployers (Article 13), human oversight (Article 14), accuracy, robustness and cybersecurity (Article 15) and a quality management system (Article 17). They then complete conformity assessment (Article 43), affix CE marking (Article 48) and register in the EU database (Article 49) [13] [15]. Deployers carry their own obligations under Article 26, and certain deployers must perform a fundamental rights impact assessment under Article 27.

3 Designing one evidence set

The three frameworks ask for overlapping evidence in different vocabularies. One risk assessment, built properly, can serve NIST's Map and Measure functions, ISO/IEC 42001's risk assessment and treatment requirements, and the EU AI Act's risk management article at once. The design problem is to produce that assessment once and to keep it current, instead of writing three documents that drift apart.

3.1 Design rule

Every governance artifact is produced at the point where the work happens, tagged with the framework provisions it satisfies, and stored once. Framework-specific deliverables (an ISO/IEC 42001 statement of applicability, an EU AI Act technical file, a NIST AI RMF profile) are generated from the tagged record. No framework-specific document is authored that isn't derived from the shared record. If a document can't be derived, that's a signal the underlying evidence is missing.

3.2 Crosswalk

Table 2 maps governance activities to all three frameworks. It is the spine of a cross-framework control register. The mapping is deliberately at the level of activities: each framework is broad, an activity often touches several provisions, and certification bodies and notified bodies will each want evidence in their own terms. Organizations should refine each row against the source texts.

Table 2. Activity-level crosswalk

Governance activity	NIST AI RMF	ISO/IEC 42001	EU AI Act (high-risk)
AI policy, roles and accountable leadership	Govern	Clause 5; A.2, A.3	Art. 17 (quality management system)
Inventory and context of each AI system	Map	Clause 4; A.6	Art. 6 (classification); Art. 49 (registration)
Risk assessment and treatment	Map, Measure, Manage	Clauses 6.1.2, 6.1.3 and 8	Art. 9 (risk management system)
Impact on individuals and groups	Map	Clause 6.1.4; A.5	Art. 27 (fundamental rights impact assessment, certain deployers)
Data quality and governance	Measure	A.7	Art. 10 (data and data governance)
Technical documentation	Govern, Map	Clause 7.5; A.6	Art. 11 and Annex IV
Logging and traceability	Measure, Manage	A.6	Art. 12 (record keeping)
Information for users and affected people	Govern	A.8	Art. 13 (transparency to deployers); Art. 50 where applicable
Human oversight	Manage	A.9	Art. 14 (human oversight)
Testing for accuracy, robustness and security	Measure	Clause 8; A.6	Art. 15 (accuracy, robustness, cybersecurity)
Monitoring after deployment	Measure, Manage	Clause 9.1	Art. 72 (post-market monitoring); Art. 73 (serious incidents)

Governance activity	NIST AI RMF	ISO/IEC 42001	EU AI Act (high-risk)
Third-party and supplier AI	Govern, Map	A.10	Art. 25 (value chain responsibilities)
Internal audit, review and improvement	Govern	Clauses 9.2, 9.3 and 10	Art. 17 (quality management system)

ISO/IEC 42001 references are to the 2023 edition; Annex A objectives are cited at objective level (A.2 to A.10). EU AI Act references are to Regulation (EU) 2024/1689 [13].

3.3 How much does ISO/IEC 42001 cover?

Published estimates of how much of the EU AI Act's high-risk obligations an ISO/IEC 42001 management system covers cluster between 60 and 80 percent (Figure 4). The Cloud Security Alliance puts it at roughly 70 to 80 percent of the organizational foundation [16]. Other analyses put it nearer 60 to 70 percent [17]. These are practitioner estimates, not official figures, and the precise number matters less than where the gaps fall.

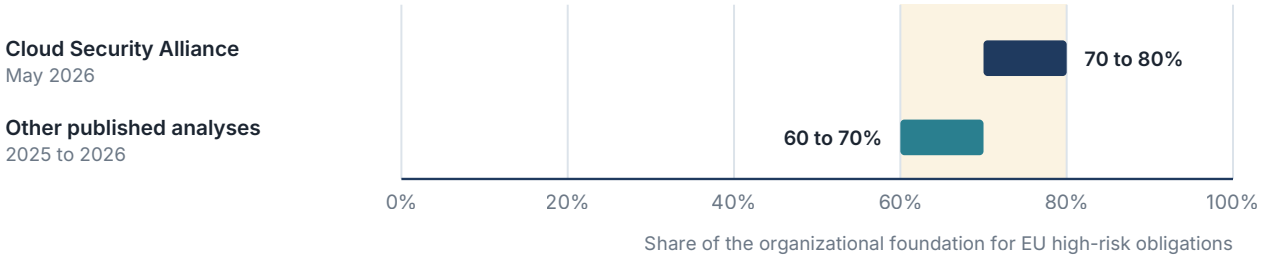


Figure 4. Published estimates of ISO/IEC 42001 coverage of EU AI Act high-risk obligations. Estimates by practitioners, not regulators [16] [17]. The shaded band marks the combined 60 to 80 percent range.

3.4 Where the gaps are

The remaining obligations fall into two groups. The first is procedural: conformity assessment before a high-risk system is placed on the market, CE marking, registration in the EU database and the Act's serious incident reporting duties. No management system standard addresses these. The second is product-level specificity. ISO/IEC 42001 asks an organization to manage AI risk systematically. The Act asks whether a specific system meets specific requirements: technical documentation with the contents set out in Annex IV, data governance for that system's training, validation and testing data, measured accuracy and robustness, and assessment of risks to health, safety and fundamental rights. A certified management system makes that evidence much easier to produce. It doesn't produce it.

3.5 Harmonized standards are the lever to watch

Under the Act, presumption of conformity comes from harmonized European standards. ISO/IEC 42001 is a management system standard and doesn't on its own confer that presumption for system-level requirements. The Cloud Security Alliance notes that a harmonized standard for the Act's quality management system obligation, prEN 18286, is in development [16]. Organizations planning toward December 2027 should track which harmonized standards are published and shape their evidence to match them.

4 Reference architecture: system of record and control plane

An AI governance program needs two kinds of machinery. A **system of record** holds the inventory, risk assessments, policies, approvals and evidence, and produces what auditors and regulators ask for. A **control plane** sits in the path of live AI traffic and enforces policy on each call: which models may be used with which data, which outputs are blocked, when an agent must stop. Governance platforms are built primarily for the first job. Model gateways, guardrails and policy engines do the second. A program that buys one and assumes it covers both will find the gap at audit time or in an incident.

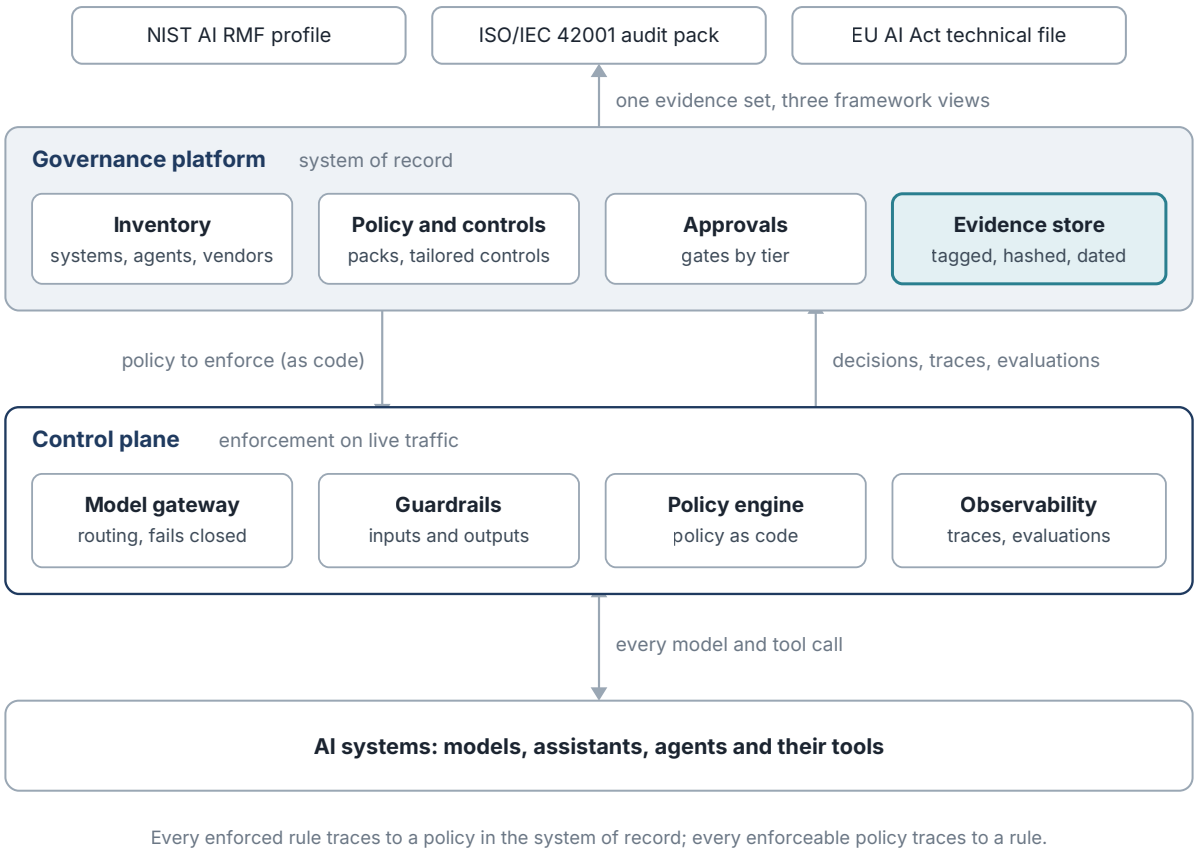


Figure 5. Reference architecture. The governance platform defines policy and holds evidence; the control plane enforces policy on live traffic and returns its decisions as evidence; the platform exports one evidence set in three framework views.

4.1 System of record

The system of record owns everything an auditor reads. That includes the inventory of AI systems, agents and vendors; each system's classification and internal tier; risk and impact assessments; the tailored control set and its owners; approval decisions; and the evidence store from which framework exports are generated. It is also where accountability lives, so every inventory entry and every control has a named owner.

4.2 Control plane

The control plane owns everything that has to happen on each call. A **model gateway** routes traffic, applies data-classification rules to model selection and fails closed when a check can't be made. **Guardrails** inspect inputs and outputs for sensitive data, unsafe content and schema violations. A **policy engine** evaluates rules expressed as code (Open Policy Agent with Rego, or Cedar, for example) kept separate from the guardrails engine so the governance function can read and review what is actually enforced. Agent-specific controls add tool allowlists, budget caps and loop breakers. **Observability** captures traces and evaluation results, and in regulated sectors it usually runs inside the organization's own environment so sensitive trace data doesn't leave it.

4.3 Interfaces between the layers

Two flows connect the layers. Downward, enforceable policies are published from the system of record to the policy engine as versioned code. Upward, the control plane sends decision logs, trace summaries, evaluation results and incident events, which become evidence. The property to test for is bidirectional traceability: every enforced rule cites a policy identifier in the system of record, and every policy marked enforceable cites at least one rule. A simple report of policies with no enforcing rule, and rules with no policy, should come back empty for every tier 3 and tier 4 system.

4.4 The evidence record

Evidence that can be tagged, verified and aged needs a minimum structure. Table 3 sets out the fields recommended here. Two of them do most of the work. The content hash lets an auditor confirm an artifact hasn't changed since it was collected. The freshness rule makes stale evidence count as missing, which is what keeps documentation from quietly drifting away from the systems it describes.

Table 3. Recommended minimum evidence record

Field	Purpose	Example
Evidence ID	Stable identifier that exports and audits reference	EV-2026-04187
Control references	Provisions this item satisfies, across frameworks	NIST MEASURE; ISO 42001 A.6; EU Art. 15
System ID and version	The inventory entry and release the evidence describes	SYS-0142 v3.2
Source system	Where the artifact came from	Model registry; gateway log; ticketing
Collection method	Pulled automatically, or attested by a person	Automated
Observed at	When the underlying fact was true	Timestamp, UTC
Content hash	Integrity check on the stored artifact	SHA-256 digest
Owner	Person accountable for accuracy	Named control owner
Freshness rule	Maximum age before the item counts as missing	90 days, or on each release
Retention	How long the item is kept, and why	Per records schedule

Field set is the author's recommendation, not a requirement of any of the three frameworks. Example values are illustrative.

5 Worked example: Credo AI

Credo AI describes its platform as covering discovery, assessment, governance, monitoring and reporting across AI agents, models and applications [21]. It is used here as a worked example because it publishes policy packs for all three frameworks. Table 4 summarizes the capabilities relevant to them and where each lands in the architecture of Section 4. All descriptions are taken from the vendor's public product page as of November 2026.

Table 4. Credo AI capabilities relevant to the three frameworks

Module	Described capability	Role in the architecture
AI Registry and discovery	Inventory of use cases, models, vendors and agents; shadow AI discovery; Agent Registry with agent cards (purpose, tools, data sources, guardrails), platform and MCP server governance, and dependency mapping	System of record: inventory (NIST Map; ISO clause 4; EU Arts. 6, 49)
Risk intelligence	AI-specific risk assessment with a control library; aggregate scoring with policy inheritance; automated red-teaming and drift detection	System of record: assessment (NIST Map, Measure; ISO 6.1; EU Art. 9)
Compliance and policy engine	Policy packs for the EU AI Act, NIST AI RMF, ISO/IEC 42001 and SOC 2; approval gates; automated evidence generation; audit trails; custom mapping	System of record: controls, approvals, evidence
Runtime governance	Ingestion and continuous evaluation of agent traces; human-in-the-loop escalation; real-time compliance alerts	Consumes control-plane traces; monitoring evidence (ISO 9.1; EU Art. 72)
GAIA	Governance assistant for intake, registration, and risk and control mapping; remediation agents	Accelerates system-of-record work
Integrations	AWS, Azure, Google Cloud, Databricks, Snowflake; Azure AI Foundry, LangChain, CrewAI, AutoGen; ServiceNow, Archer, OneTrust, Qualys; GitHub, MLflow, Jira, Confluence, Slack; APIs and SDKs	Evidence sources (Section 6, step 5)

Source: Credo AI product page, accessed November 2026 [21]. Not independently tested.

5.1 Maturity notes

Two items on the same product page matter for planning. The Agent Governor is labeled a research preview. Enforcement integration with CI/CD pipelines, cloud access security brokers and API gateways is listed as planned [21]. Until those integrations are generally available, runtime enforcement for high-tier systems has to come from a separate gateway and policy engine, connected as described in Section 4.3. Buyers should confirm the status of both features against their own timeline.

5.2 Market context

According to its product page, Credo AI was named a Leader in the Forrester Wave for AI Governance Solutions in Q3 2025 and is mentioned in Gartner's 2025 Market Guide for AI Governance Platforms [21]. A market guide lists representative vendors and doesn't rank them. Comparable platforms in the category include Holistic AI, Trustible, Modulos and IBM watsonx.governance, and the approach in this paper applies to any of them.

6 Implementation sequence

The sequence below takes an organization from scattered AI activity to one evidence set serving all three frameworks. Each step names the governance outcome first so that it translates to any platform, and each ends with an exit criterion that should be met before the dependent steps start. Figure 6 groups the steps into phases.

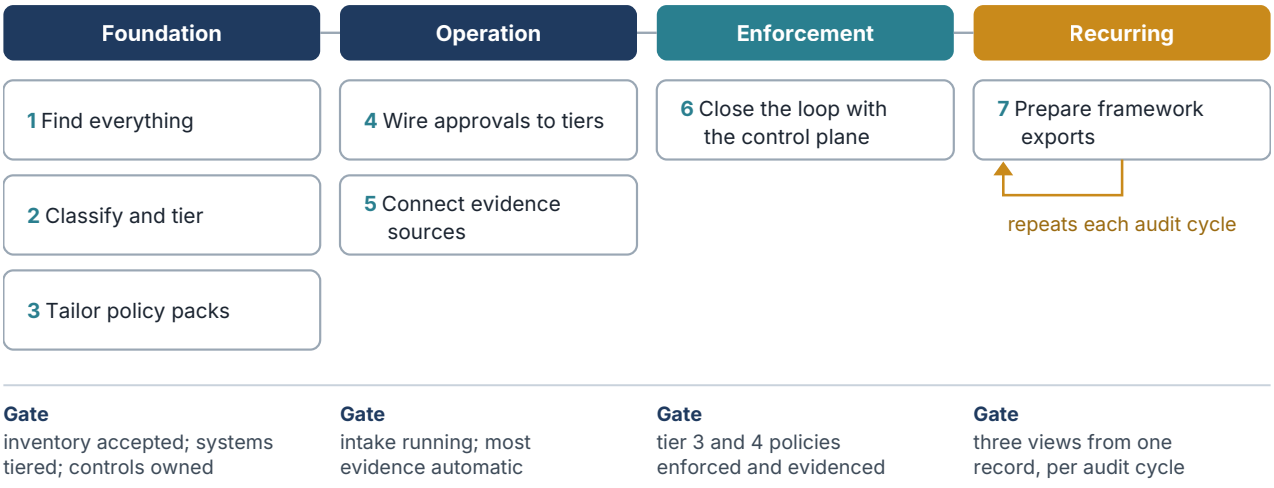


Figure 6. Implementation phases and exit gates. Steps within the foundation phase can run in parallel once the inventory exists. The diagram shows dependency, not calendar duration.

1. **Find everything.** Stand up the inventory and run shadow AI discovery across the cloud and SaaS estate. Register custom models, AI features inside purchased software, general-purpose assistants and agents, and record vendors. For each agent, record its purpose, tools, data sources, guardrails and the person who delegated the work to it. In Credo AI this is the AI Registry, vendor registry and Agent Registry.

   Exit: one authoritative inventory, accepted by leadership as the working list.

2. **Classify and tier.** For each system, record its EU AI Act classification and the organization's own internal tier. Platform risk scoring helps, but the tiering rule must be the organization's and must be written down. Section 6.1 gives a rule that works.

   Exit: every system has a classification, a tier and an owner.

3. **Tailor the policy packs.** Load the NIST AI RMF, ISO/IEC 42001 and EU AI Act packs, then map each requirement to the organization's actual controls, mark what doesn't apply and why, and add internal and sector policies the packs don't contain. Adopting packs wholesale produces a long list of requirements nobody owns.

   Exit: a cross-framework control set with an owner for every control.

4. **Wire approvals to tiers.** Configure governance workflows so the approval path depends on the tier (Table 5). Publish the service levels. Teams route around governance that's slower than the alternative, so the governed path has to be the fastest path.

   Exit: intake running, with measured turnaround by tier.

5. **Connect evidence sources.** Integrate the platform with the systems where evidence already exists: the model registry and MLflow for versions and evaluations, source control for code and prompt changes, ticketing for approvals and incidents, cloud platforms for deployment records, and GRC tools for control testing. Evidence pulled from systems is current and defensible. Evidence typed into forms goes stale.

   Exit: the majority of evidence items populate automatically and carry the fields in Table 3.

6. **Close the loop with the control plane.** Route model traffic for tier 3 and tier 4 systems through a gateway that enforces the policies the platform defines, and feed gateway decisions and traces back as evidence (Section 4.3). Where the platform's own enforcement integrations are still planned, this step is essential.

   Exit: high-tier policies are enforced on live traffic, and their enforcement is evidenced.

7. **Prepare the framework exports.** For ISO/IEC 42001, build the statement of applicability from Annex A, link each control to its evidence, and run internal audit and management review. For the EU AI Act, assemble Annex IV technical documentation for each high-risk system and identify the conformity assessment route. For NIST AI RMF, produce a profile of current and target states across the four functions.

   Exit: three framework views generated from one evidence base. Repeats each audit cycle.

6.1 Tiering and approval authority

Step 2 needs a written tiering rule. The one recommended here places each system on two axes: the kind of AI component involved, and the consequence if it gets something wrong (Figure 7). Most systems in most enterprises land in tiers 1 and 2 and need very little, which frees time and attention for the few at tier 4.

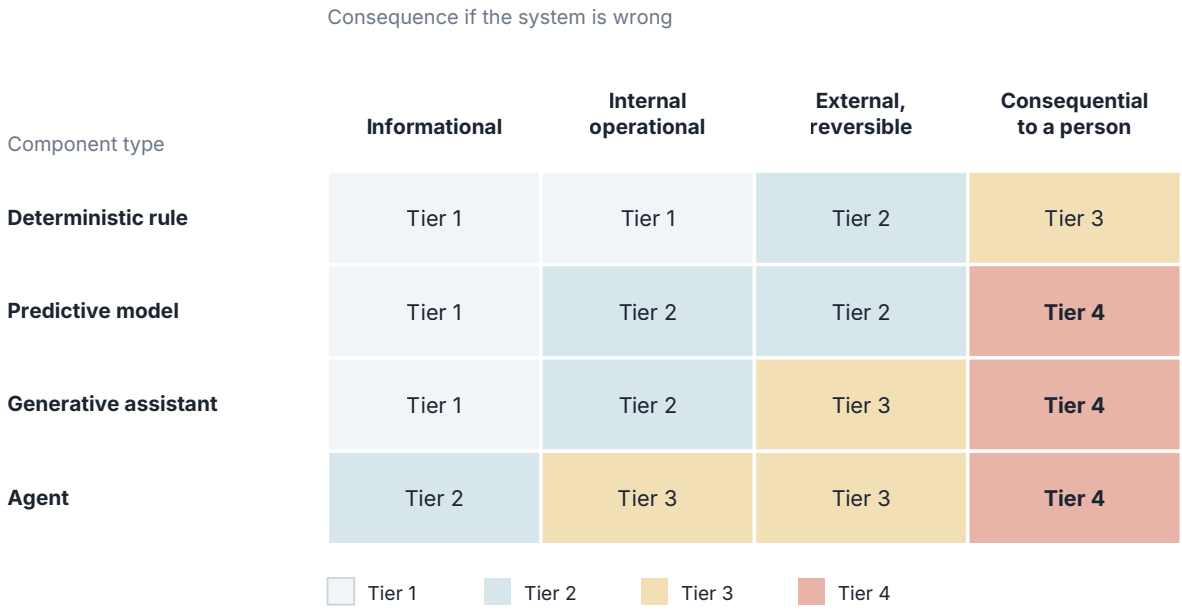


Figure 7. Component-by-consequence tiering. Consequence, more than technology, sets the tier: every probabilistic component reaches tier 4 once a person's eligibility, coverage, credit, employment or health is at stake.

A grid on its own invites optimistic placement. The rules below close the most common gaps.

- **Composite rule.** A system takes the highest tier of any component-consequence pair it contains. A mostly deterministic pipeline with one generative step that drafts adverse notices is a tier 4 system.
- **Agentic floor.** Any agent is at least tier 2 whatever its stated purpose, and any agent with write access to a system of record is at least tier 3. What an agent can touch bounds what it can break.
- **Directional consequence.** A system that can approve or deny is tiered by the denial. An erroneous approval and an erroneous denial don't harm the same person in the same way, and some laws now reflect that asymmetry directly (Section 8.1).
- **Drift-right detection.** Each tier assumes a level of human checking, and people who check reliable systems check less over time. Monitor override and correction rates for tier 3 and 4 systems. When people stop changing outputs, either restore the checks or move the system up a tier.

Table 5. Approval authority by tier

Tier	Approver	Target turnaround	What the approver reviews
1	Self-service from the approved tool register	Same day	Tool is on the register; use fits acceptable-use policy
2	Domain owner accountable for the work	Within a week	Inventory entry, basic evaluation, data handling
3	AI governance office, with risk and security input	Two to three weeks	Risk assessment, evaluation plan, oversight design, monitoring, gateway routing
4	Governance committee with the accountable executive	Set per case	Impact assessment, independent validation, deterministic decision gate, legal review

Turnaround targets are illustrative. What matters is that they are published, measured and met.

6.2 Pacing

Steps 1 to 3 are the foundation and can run in parallel once the inventory exists. Steps 4 and 5 deliver most of the day-to-day value. Step 6 is where governance stops being paperwork for the highest-risk systems. Step 7 recurs on each audit cycle and as the EU dates approach.

> **THE COMMON MISTAKE**
> Programs often start at step 7: buy a platform, load the packs and generate audit documentation before the inventory and controls exist. The documents look complete and fall apart at the first evidence request.

7 Requirement-to-capability map

A platform supports compliance. It doesn't deliver it. Table 6 maps the main requirements across the three frameworks to the Credo AI capability that supports each, and to the work the organization still owns. The right-hand column is the work plan.

Table 6. Requirements, supporting capability and retained ownership

Requirement	Supporting Credo AI capability	What the organization still owns
Complete AI inventory (all three)	AI Registry; shadow AI discovery; vendor and Agent Registry	Deciding what counts as an AI system; holding owners accountable for accuracy
Risk classification and tiering	Risk scoring; EU AI Act classification support	The tiering rule and the final classification decision
Risk assessment and treatment (NIST Map, Manage; ISO 6.1; EU Art. 9)	Risk and control library; assessments; policy inheritance	Judgments on context, severity and acceptable risk; treatment decisions
Policies and controls	Policy packs for EU AI Act, NIST AI RMF, ISO/IEC 42001, SOC 2; custom mapping	Tailoring packs; implementing controls in the real systems
Approval and accountability	Workflows with approval gates; audit trails	The approval-authority matrix; who can stop a deployment
Testing and evaluation (NIST Measure; EU Art. 15)	Automated red-teaming; drift detection; evaluation integrations	Defining acceptable performance; pre-registering thresholds; independent validation for tier 4
Human oversight (EU Art. 14)	Human-in-the-loop escalation workflows	Oversight that works in practice, measured by whether it catches errors
Runtime enforcement	Trace ingestion and evaluation; gateway and CI/CD enforcement listed as planned	Gateway, guardrails and policy engine acting on live traffic
Logging and record keeping (EU Art. 12)	Audit trails; evidence generation	System-level logging in the AI systems, with appropriate retention
Technical documentation (EU Art. 11, Annex IV)	Documentation scaffolding and evidence	Accurate system-specific content, kept current through changes
Conformity assessment, CE marking, EU registration	Evidence packaging	The legal process, with counsel and, where required, a notified body
ISO/IEC 42001 certification	Control-to-evidence mapping; audit-ready reporting	Statement of applicability; internal audit; management review; the external audit
Post-market monitoring and incidents (EU Arts. 72, 73)	Real-time monitoring and alerts; incident workflows	Response, root cause, corrective action and regulatory reporting

Capability descriptions from the vendor product page [21].

8 Sector considerations

The three frameworks are sector-neutral. Healthcare and financial services add obligations that shape how they're applied and what a governance platform has to handle. Vendor policy packs cover the cross-sector frameworks well; sector rules usually have to be added as custom policies with owners in compliance and legal, and programs should budget time for that in step 3.

8.1 Healthcare

Protected health information in governance data. Runtime governance depends on traces of what AI systems received and produced, and in healthcare those traces often contain protected health information (PHI). Before connecting trace ingestion, confirm whether the platform will receive PHI, whether a business associate agreement is in place, where data is processed and retained, and whether traces can be minimized or de-identified before they leave the organization's environment. Many health organizations keep detailed traces in self-hosted observability and send the governance platform only metadata and evaluation results.

Coverage decisions. California's SB 1120, effective January 2025, requires that medical necessity determinations be made only by a licensed physician or qualified health professional and bars AI tools from denying, delaying or modifying care on that basis [22]. Texas's SB 815, effective September 2025, prohibits utilization review agents from using an automated decision system to make an adverse determination, wholly or partly [23]. CMS requires Medicare Advantage determinations to rest on the individual's circumstances and on publicly posted criteria that algorithms can't alter [24]. For each utilization management system, the program should record where the boundary between automated support and licensed human decision sits and how it is enforced.

Insurance regulation. The NAIC Model Bulletin on insurers' use of AI has been adopted in some form by nearly 30 states and expects a documented AI systems program with oversight of third-party AI [20]. Colorado's SB 26-189, effective January 1, 2027, deems insurers already complying with Colorado's existing algorithmic discrimination rules to be compliant with its requirements [18].

Medical device software. AI that qualifies as a medical device sits under FDA oversight in the United States. In the EU, AI Act high-risk obligations for AI embedded in regulated products now apply from August 2, 2028 [14].

8.2 Financial services

Model risk management. Banks already validate models under supervisory model risk guidance, long anchored in SR 11-7 in the United States [25]. AI models belong in that program. The governance platform should feed the model risk inventory and validation workflow, not run a parallel one.

Credit decisions. EU AI Act Annex III lists creditworthiness assessment as a high-risk use [13]. In the United States, adverse action notice requirements already demand explanation of credit decisions, and Colorado's SB 26-189 lets creditors meet its post-adverse-outcome disclosure obligations through those existing notices [18].

9 Common claims, checked

Statements about these frameworks circulate widely in vendor content, conference talks and social posts. The governance landscape moved quickly in 2025 and 2026, and content written before then often still circulates. Table 7 checks the most common claims against sources current to November 2026. Before relying on any framework claim in a board paper, proposal or regulatory submission, check its date and its source.

Table 7. Common claims and what the sources show

Claim	Assessment	What the sources show
NIST AI RMF is the most widely adopted AI governance framework	Plausible, not measured	It is a widely used reference point and most governance platforms map to it. No authoritative adoption census was found to rank it [3].
NIST AI RMF is the most cited framework in US federal procurement	Out of date	The 2024 OMB memoranda drew on it. Their April 2025 replacements, M-25-21 and M-25-22, don't reference it by name [4].
Organizations choose NIST AI RMF because it is free, voluntary and plainly written	Accurate as description	It is free, voluntary and accessible. Why individual organizations choose it isn't documented systematically.
AWS and Microsoft have certified their AI offerings to ISO/IEC 42001	Accurate, with scope	AWS certified Bedrock, Q Business, Textract and Transcribe in November 2024 [7]; Microsoft certified Microsoft 365 Copilot and Copilot Chat in March 2025 [10]. Certificates cover the named services; customers aren't certified by association [9].
ISO/IEC 42001 covers 70 to 80 percent of EU AI Act high-risk requirements	Estimate	The Cloud Security Alliance estimates roughly 70 to 80 percent of the organizational foundation [16]; other analyses say 60 to 70 percent [17]. Gaps are mainly conformity assessment, CE marking, registration and system-level documentation.
The EU AI Act applies to any organization whose AI touches people in the EU	Accurate in substance	It applies to providers and deployers outside the EU where their system's output is used in the Union [15]. Which obligations apply depends on role and risk tier.
EU high-risk obligations apply from August 2026	Out of date	The Digital Omnibus moved them to December 2, 2027 and August 2, 2028. Transparency obligations did take effect in August 2026 [14].
ISO/IEC 42001 certification provides a legal safe harbor	Depends on jurisdiction	The original Colorado AI Act offered a framework-based defense but was repealed and replaced by SB 26-189 before taking effect [19]. Under the EU AI Act, presumption of conformity comes from harmonized standards [16].

10 Evaluating a governance platform

The questions below apply to Credo AI and to any comparable product. They separate a platform that will produce defensible evidence from one that will produce attractive dashboards.

Where does the evidence come from?
Ask the vendor to show, for a sample control, whether its evidence is pulled from a connected system or entered by a person. Evidence from systems is current and hard to dispute. Evidence from forms is a snapshot of someone's belief.

What does the platform enforce, and what does it only record?
Get a clear answer on which policies the product itself can block or stop at runtime, and which it monitors and reports. Then decide which gateway or policy engine will do the enforcing.

What happens to sensitive data in traces?
Ask where trace data is processed and stored, how long it's kept, whether it can be minimized before ingestion and, in healthcare, whether the vendor will sign a business associate agreement.

How mature is agent governance?
Agent registries, dependency graphs and runtime agent controls are new across the category. Ask which features are generally available, which are in preview, and what's on the roadmap with dates.

Can the evidence leave?
Confirm that inventory, assessments, approvals and evidence can be exported in usable formats with their hashes and timestamps intact. Governance records may need to outlive the contract.

How are policy packs maintained?
Ask how quickly packs were updated after the EU Digital Omnibus and Colorado's SB 26-189, and how updates reach customers' tailored versions without overwriting local mappings.

Can it carry sector rules?
Test whether custom policies for state utilization review laws, CMS rules or banking supervision expectations can be added and mapped as easily as the built-in packs.

10.1 Limits of any platform

No platform makes the judgments governance depends on: whether a risk is acceptable, whether a use case should exist, who is accountable. No platform performs conformity assessment or certification; accredited third parties do. And no platform can produce evidence for controls that don't exist in the underlying systems. A platform makes good governance faster and more visible. It can also make weak governance look complete, which is the main risk to guard against when buying one.

11 Conclusion

The three frameworks will keep moving. NIST is revising the AI RMF, harmonized European standards are still being written, and Colorado replaced its AI Act before the original law ever took effect. An organization that answers each change with a new document set will spend its governance budget on paperwork. One that has an inventory, a written tiering rule, a crosswalked control set, a control plane that enforces high-tier policy and an evidence store that ages its own contents can absorb each change as a mapping update.

The practical starting point is the same regardless of platform: build the inventory, write the tiering rule, and connect the first evidence sources. The exports come last, and they come easily once the record beneath them is real.

About the author

Aejaz Sheriff Quaraishi is an enterprise and AI architect with nearly three decades in enterprise architecture, much of it in healthcare payer platforms. His work focuses on governed AI for regulated industries: AI control planes, model and agent governance, and the evidence that regulators and auditors ask for. He holds TOGAF 9.1 and HIPAA Security Officer certifications. He can be reached at linkedin.com/in/asheriff.

Disclosure

The author has no commercial relationship with Credo AI or any other vendor named in this paper. Through his own company he has a commercial interest in a product that generates governance configuration and compliance evidence for AI coding agents, a category adjacent to the platforms discussed here. Descriptions of Credo AI's capabilities are taken from the vendor's public product page as of November 2026 and haven't been independently tested. The views expressed are the author's own and don't represent any employer or client.

Limitations

Regulatory summaries reflect sources available on November 4, 2026 and are provided for architecture and planning purposes. They are not legal advice. Coverage estimates in Section 3.3 are practitioner estimates, not official figures. The evidence record (Table 3), tiering rule (Figure 7) and approval matrix (Table 5) are the author's recommendations.

Companion papers in preparation

- *Who Decided? Deterministic Safety for AI in Health Plan Utilization Management*
- *A Policy Without a Control: Governance as Architecture for Enterprise AI*
- *The Human-in-the-Loop Illusion: Architectural Safety Guarantees for Clinical AI*

References

1. National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework* (*AI RMF 1.0*), NIST AI 100-1. January 2023. https://www.nist.gov/itl/ai-risk-management-framework
2. National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST AI 600-1. July 2024.
3. Vorp Labs. NIST AI RMF status and revision tracker (structure, Generative AI Profile, federal posture). Checked July 2026. https://vorplabs.com/security-framework-changes/nist-ai-rmf
4. Nelson Mullins. Trump administration issues guidance on use, deployment and procurement of AI (OMB M-25-21, M-25-22). 2025. https://www.nelsonmullins.com/insights/blogs/ai-task-force/ai/trump-administration-issues-guidance-on-use-deployment-and-procurement-of-ai
5. ISO/IEC 42001:2023. *Information technology: Artificial intelligence: Management system*. International Organization for Standardization, December 2023.
6. Neowin. Microsoft 365 Copilot clears AI security audit once again (ISO/IEC 42001 recertification). May 2026. https://www.neowin.net/news/microsoft-365-copilot-clears-ai-security-audit-once-again/
7. Amazon Web Services. AWS achieves ISO/IEC 42001:2023 Artificial Intelligence Management System accredited certification. November 2024. https://aws.amazon.com/blogs/machine-learning/aws-achieves-iso-iec-420012023-artificial-intelligence-management-system-accredited-certification
8. Amazon Web Services. AWS successfully completed its first surveillance audit for ISO 42001:2023 with no findings. February 2026. https://aws.amazon.com/blogs/security/aws-successfully-completed-its-first-surveillance-audit-for-iso-420012023-with-no-findings
9. Amazon Web Services. ISO/IEC 42001:2023 FAQs. https://aws.amazon.com/compliance/iso-42001-faqs/
10. Microsoft. Microsoft 365 Copilot achieves ISO/IEC 42001:2023 certification. March 25, 2025. https://techcommunity.microsoft.com/blog/Microsoft365CopilotBlog/microsoft-365-copilot-achieves-isoiec-420012023-certification/4397144
11. Microsoft. ISO/IEC 42001:2023 Artificial Intelligence Management System offering. Microsoft Learn. https://learn.microsoft.com/compliance/regulatory/offering-iso-42001
12. LRQA. What ISO 42001 does and does not get you under the EU AI Act. 2026. https://www.lrqa.com/en/insights/articles/what-iso-42001-does-and-does-not-get-you-under-the-eu-ai-act/
13. European Union. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). Official Journal, July 12, 2024. https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202401689
14. Future of Privacy Forum. The AI Act implementation timeline: what changes under the AI Omnibus? 2026. https://fpf.org/blog/the-ai-act-implementation-timeline-what-changes-under-the-ai-omnibus
15. Alation. AI compliance reporting: how to generate audit-ready documentation for ISO 42001, EU AI Act and NIST RMF. August 5, 2026. https://www.alation.com/blog/ai-compliance-reporting-iso-42001-eu-ai-act-nist-rmf/
16. Cloud Security Alliance AI Safety Initiative. EU AI Act risk tiers: the ISO 42001 compliance path. May 5, 2026. https://labs.cloudsecurityalliance.org/research-rb/csa-whitepaper-eu-ai-act-iso42001-enterprise-compliance-2026/
17. Presencis. EU AI Act vs ISO 42001: complete comparison guide. 2026. https://cdn.presencis.com/regulations/comparisons/eu-ai-act-vs-iso-42001
18. Crowell & Moring, via Mondaq. Colorado hits reset on AI regulation: SB 26-189 repeals and reenacts the Colorado AI Act. May 14, 2026. https://www.mondaq.com/unitedstates/new-technology/1794604/colorado-hits-reset-on-ai-regulation-sb-26-189-repeals-and-reenacts-the-colorado-ai-act
19. Holland & Knight, via JD Supra. Colorado governor signs SB 189, significantly amending the state's AI law. May 2026. https://www.jdsupra.com/legalnews/colorado-governor-signs-sb-189-6332492/
20. National Association of Insurance Commissioners. NAIC survey reveals majority of health insurers embrace AI. May 20, 2025. https://content.naic.org/article/naic-survey-reveals-majority-health-insurers-embrace-ai
21. Credo AI. AI Governance Platform product page. Accessed November 2026. https://www.credo.ai/product

22. Law360. A look at California's new AI law for health insurers (SB 1120). 2024. https://www.law360.com/articles/1888226/a-look-at-calif-s-new-ai-law-for-health-insurers

23. Texas Senate Research Center. Bill analysis, S.B. 815 (enrolled), 89th Legislature. June 3, 2025. https://capitol.texas.gov/tlodocs/89R/analysis/html/SB00815F.htm

24. Manatt Health. CMS weighs in on the use of algorithms and artificial intelligence in coverage determinations (February 6, 2024 FAQ). https://www.manatt.com/insights/newsletters/health-highlights/cms-weighs-in-on-the-use-of-algorithms-and-artific

25. Board of Governors of the Federal Reserve System and Office of the Comptroller of the Currency. *Supervisory Guidance on Model Risk Management* (SR 11-7). April 4, 2011.